Portada

SGSIREG001002 · Versión 2.0 · Borrador · Aprobación pendiente

Vista de lectura del libro Excel, con sus hojas, campos y valores calculados. Escenario ficticio. Revisión iniciada el 27/09/2026; edición de lectura del 28/09/2026. El historial se conserva y no acredita operación ni aprobación.

SGSI-REG-001 (Registro de Riesgos) y SGSI-REG-002 (Plan de Tratamiento del Riesgo)

Organización: Atalaya Gestión Patrimonial SL

Versión: 2.0 | Estado: Borrador | Revisión: 27/09/2026 | Aprobación: pendiente conforme a DOC-002 §4. Fecha de corte sin cambios. Clasificación: Restringida

Propietario: Comité de Seguridad Convergente | Autor: el consultor (externo) | Revisión de septiembre pendiente de aprobación; historial anterior conservado.

Objeto

Registro previsto en SGSI-DOC-004. Un único libro con dos registros del SGSI: el catálogo de escenarios de riesgo valorados

(SGSI-REG-001) y el plan de tratamiento con su riesgo residual y su aceptación (SGSI-REG-002). Se mantienen juntos porque

comparten identificadores y se revisan en el mismo acto; separarlos garantiza que uno de los dos quede desactualizado.

Hojas

«Criterios» — Resumen operativo de SGSI-DOC-004: escalas, anclajes de probabilidad, regla de convergencia, vocabularios y

estado del sistema a fecha de corte. Es la hoja que hay que leer antes que ninguna otra.

«Registro de riesgos» — 25 escenarios narrados como cadenas, con interfaz, dominios, valoración por cuatro dimensiones de

impacto, probabilidad, nivel y decisión de tratamiento.

«Controles» — 64 controles, uno por fila, con el eslabón de la cadena que rompe, dominio, estado, evidencia, periodicidad de

verificación y plan al que pertenecen. Una fila por control y no una lista dentro de una celda: es lo que permite que la regla

de convergencia se verifique por máquina (ver «Criterios», bloque de verificación automática).

«Plan de tratamiento» — 16 planes con responsable, plazo, riesgo residual estimado, aprobación del plan y aceptación del residual por el propietario del riesgo (ISO/IEC 27001 6.1.3 f) y ratificación del Comité.

Historial de versiones

1.0 | 26/05/2026 | El consultor | Emisión inicial: 17 escenarios y plan de tratamiento asociado.

1.1 | 24/07/2026 | El consultor | Revalorización de la probabilidad con el anclaje por condiciones de exposición. Alta de los

escenarios RSC-018 a RSC-025 (fallos de ejecución y operativa material). Desglose de los controles a fila única con

dominio, estado, evidencia y periodicidad de verificación. Aprobada por el Comité el 24/07/2026.

1.2 | 24/07/2026 | El consultor | Unificación del vocabulario de estado con SGSI-REG-003 y declaración del estado de cobertura

a fecha de corte (HD-06). Aprobada por el Comité el 24/07/2026.

1.3 | 24/07/2026 | El consultor | Verificación documental de cierre, adoptada en la misma sesión: corrección del formato

declarado de fecha_ultima_verificacion a DD/MM/AAAA, coherente con el dato del registro y con el validador; alta del

bloque de verificación automática de la regla de convergencia en «Criterios»; alta de las columnas de aceptación del

riesgo residual en «Plan de tratamiento», exigidas por los criterios de aceptación de SGSI-DOC-004 §4.4 y hasta ahora

sin soporte en el registro; y alta de esta portada de control documental. Sin cambios de valoración ni de tratamiento.

1.4 | 24/07/2026 | El consultor | Revisión de coherencia cruzada: corrección del significado declarado de la columna «Dominios»,

que indica los dominios que el escenario atraviesa y no la cobertura prevista (encabezado renombrado a «Dominios del escenario»);

normalización del vocabulario de la columna «Interfaz» al de las diez interfaces declaradas en SGSI-DOC-001 §7.4, que hace

verificable la regla de completitud en los dos sentidos (cierre efectivo de HD-04); valoración del riesgo residual de los planes

que agrupan varios escenarios por regla del máximo, con corrección de PT-09 y PT-13; y reordenación de la fila C-055 en la hoja

«Controles». Sin cambios en la valoración inherente ni en la selección de controles. Aprobada por el Comité el 24/07/2026.

1.5 | 24/07/2026 | El consultor | Revisión de coherencia cruzada de cierre. (a) Renumeración de la columna «Eslabón que rompe» de los controles de RSC-001 a la cadena de seis eslabones de SGSI-DOC-004 Anexo B: C-001, C-002 y C-005 al eslabón 3 y C-003 y C-004 al eslabón 5. La numeración anterior describía una cadena de cuatro eslabones que ningún documento del sistema sostiene, y dejaba sin correspondencia el candado que exige a cada control declarar qué eslabón rompe. (b) Reescritura de la cadena de RSC-001, que conservaba la narrativa retirada en la v2.0 de ESC-001 (captación por redes con un actor único) en lugar del encargo delegado a un intermediario. (c) Corrección del eslabón de detección de 4 a 5 y de la lectura de los eslabones 1 y 2 como carencia, siendo inalcanzables por diseño. (d) Alta del vocabulario de estado de plan y normalización de la columna «Estado» de «Plan de tratamiento», que mantenía el vocabulario que HD-06

dio por retirado. (e) Alta de la columna de aprobación del plan por el propietario del riesgo y reformulación de la aceptación del residual, que la norma atribuye al propietario y este registro atribuía solo al Comité (6.1.3 f).

(f) Precisión de los dos supuestos del estado PARCIAL, que la definición vigente no distinguía pese a convivir en el registro. (g) Retirada del plazo «mínimo 48 horas» de C-006, que no figura en ningún documento del sistema. (h) Actualización de la columna «ref_27002» de C-021, C-022, C-026, C-032, C-033 y C-052 para que la trazabilidad con SGSI-REG-003 sea simétrica en los dos sentidos, y de la referencia al Anexo A de PT-01, PT-07 y PT-14. (i) Retirada del sufijo «— aprobado» del campo Estado, ajeno al vocabulario de SGSI-DOC-002 §3, y alta del pie de control documental en todas las hojas.

Sin cambios en la valoración inherente, en el residual ni en la selección de controles. Aprobada por el Comité el 24/07/2026.

1.6 | 20/08/2026 | El consultor | Reclasificación de Confidencial a Restringida por aplicación de la regla del nivel superior de SGSI-DOC-002 §5: la propia portada de este registro declara que contiene «la relación completa de vulnerabilidades del sistema de protección de la familia», que es la definición literal de Restringida («su exposición habilita daño directo a personas»). Hallazgo registrado como HD-07 en SGSI-DOC-010 §4.1 y en SGSI-REG-006, con reclasificación en cascada de SGSI-REG-006 (de Interna a Confidencial) y de SGSI-DOC-010 (de Interna a Confidencial), aplicadas en el mismo acto. Sin cambios en la valoración de riesgos, en los controles ni en los planes de tratamiento.

1.6 | 20/08/2026 | Comité de Seguridad Convergente | Aprobación de la revisión 1.6.

Clasificación: Restringida. Este registro contiene la relación completa de vulnerabilidades del sistema de protección de la familia. En una organización real no se publica ni se distribuye fuera del Comité. Figura aquí porque el caso es ficticio.

Fecha de corte del sistema: 24/07/2026. Aprobado por el Comité de Seguridad Convergente (acta del Comité de 24/07/2026 y 20/08/2026).

Revisión de septiembre: los residuales de los planes siguen siendo previsiones, no resultados aceptados por ejecución. Los planes que incluyen RSC-019/RSC-020 requieren revisión del tratamiento digital y de su residual antes de considerarse completos. C-059 exige presencia desde 50.000 €.

Historial 1.7 | 20/09/2026 | Autor del caso | Corrección de coherencia y legibilidad. Deltas en correcciones_2026-09.md. Sin aprobación formal ni eficacia operativa declarada.

Historial 2.0 | 27/09/2026 | Autor del caso | Revisión por dominios aplicables. Estado Borrador; aprobación pendiente. Corte operativo 24/07/2026 conservado; no acredita implantación ni eficacia. Ver revisión 2026-09-27.

La columna de dominio es el resultado del análisis de la cadena. RSC-014 queda pendiente de concretar el medio de coacción. C-060 se retira sin reutilizar su identificador. Las cifras históricas no describen la cobertura revisada.

Criterios

SGSI-REG-001 (Registro de Riesgos) y SGSI-REG-002 (Plan de Tratamiento) | Criterios (resumen de SGSI-DOC-004)

Impacto: máximo de las 4 dimensiones (Personas, Patrimonio, Privacidad/Reputación, Legal). Escalas 1-4.

Aceptación: Bajo aceptable; Moderado con justificación del propietario; Alto lo acepta el propietario del riesgo (6.1.3 f) y lo ratifica el Comité; Crítico no aceptable como residual.

PROBABILIDAD — anclaje por acumulación de condiciones de exposición (DOC-004 §4.2, v1.1):

1 Raro — Ninguna condición de exposición presente. Requeriría que un actor fuera expresamente a por la organización.

2 Posible — Existe exposición, pero no hay señal ni intención conocida.

3 Probable — Varias condiciones apiladas: la información está disponible, el acceso es fácil, existe motivo.

4 Muy probable — Lo anterior MÁS una señal observada: ya ha ocurrido, hay indicios activos, o alguien lo ha intentado.

Regla: el nivel 4 exige haber visto algo. No se asigna por intuición ni por gravedad percibida.

Condiciones de exposición consideradas: información en abierto | acceso físico fácil o no controlado | persona con motivo dentro o cerca |

notoriedad pública del principal | precedente propio o en el entorno inmediato.

Regla de cobertura (DOC-004 §6, revisión 2.0): analizar siempre FISICO y DIGITAL; exigir cobertura solo en los dominios aplicables de cada escenario Alto o Crítico.

ORGANIZATIVO no acredita por sí solo cobertura física o digital. Dominio del escenario, dominio de la medida y bloque del Anexo A son conceptos distintos.

Cobertura efectiva según datos = IMPLEMENTADO + evidencia no vacía + verificación en plazo + alcance GENERAL documentado.

PLANIFICADO, PARCIAL, verificación vencida/futura o alcance CONDICIONADO/PENDIENTE no acreditan cobertura general.

Valorado en sesión conjunta del Comité de Seguridad Convergente. Revisión v1.1: revalorización de probabilidad con el anclaje por

condiciones y alta de los escenarios RSC-018 a RSC-025 (fallos de ejecución y operativa material), aportados por el jefe de seguridad.

VOCABULARIO DE ESTADO DE CONTROL (común a SGSI-REG-001 y SGSI-REG-003; valores exactos, en mayúsculas):

IMPLEMENTADO — el control opera y su ejecución deja evidencia registrada.

PARCIAL — el control opera pero sin evidencia registrada de su ejecución, o solo en una parte del alcance. Los dos supuestos se distinguen por la columna «evidencia»:

con identificador de evidencia (C-003, C-004, C-011, C-013, C-015) = opera y deja evidencia, pero solo en parte del alcance;

sin identificador = opera sin dejar evidencia registrada de su ejecución. Es el caso de los controles del

Anexo A que en SGSI-REG-003 figuran PARCIAL sin control propio en este registro: los físicos preexistentes

(perímetro, suministro, protección ambiental, contacto con grupos de interés) y los que se apoyan en un documento

del SGSI ya aprobado pero aún no desplegado en su totalidad. Ninguno de los dos supuestos cuenta como cobertura efectiva.

PLANIFICADO — el control no opera todavía.

NO APLICA — únicamente en SGSI-REG-003, para los controles del Anexo A declarados no aplicables.

Regla de coherencia: el estado de un control del Anexo A en la SoA es el del control menos avanzado

del registro que lo soporta. Un control del Anexo A no puede figurar más avanzado que su tratamiento. Dos excepciones

declaradas: los controles físicos preexistentes, que operan sin dejar evidencia registrada y figuran PARCIAL; y los controles

acreditados por un contrato de tercero sin control propio en el registro (8.14), que figuran con el estado que acredite ese contrato.

VOCABULARIO DE ESTADO DE PLAN (hoja «Plan de tratamiento», columna «Estado»; valores exactos, en mayúsculas):

NO INICIADO — ningún control del plan ha salido del estado PLANIFICADO.

EN CURSO — al menos un control del plan ha alcanzado PARCIAL o IMPLEMENTADO.

CERRADO — todos los controles del plan están IMPLEMENTADOS y su residual ha sido aceptado y ratificado.

Es un dominio distinto del estado de control y no debe confundirse con él: un plan describe un trabajo, un control

describe una medida. Se declara aquí porque hasta la v1.4 esta columna usaba «Planificado / En curso», vocabulario

que HD-06 dio por retirado del sistema sin advertir que seguía vivo en esta hoja.

ACEPTACIÓN DEL RIESGO RESIDUAL Y APROBACIÓN DEL PLAN (ISO/IEC 27001 6.1.3 f):

La norma exige que el plan de tratamiento lo apruebe y que el riesgo residual lo acepte el PROPIETARIO DEL RIESGO. Ambos actos se registran en columnas propias de la hoja «Plan de tratamiento». Sobre ese mínimo, esta organización añade un requisito más estricto: todo residual de nivel Alto exige además ratificación expresa del Comité de Seguridad Convergente (DOC-004 §4.4), registrada en acta. La ratificación colegiada no sustituye la aceptación del propietario; se suma a ella.

VOCABULARIO DE INTERFAZ (hoja «Registro de riesgos», columna «Interfaz»; valores exactos):

Las diez interfaces declaradas en SGSI-DOC-001 §7.4 se citan en el registro por su forma corta, una por una y separadas por «;»:

Familia | Círculo histórico | Asesores Dublín | MSP | Banca privada | Físico↔Digital | Servicios contratados | Contratas y trabajos | Entorno social | Proveedores de viaje.

Regla de completitud (DOC-004 §5.1), verificable en los dos sentidos: todo escenario del registro cita al menos una interfaz declarada, y toda interfaz declarada es citada por al menos un escenario. No se admiten valores fuera de esta lista.

VOCABULARIO DE VERIFICACIÓN (hoja Controles; criterio de asignación en DOC-004 §6):

periodicidad_dias — cada cuántos días debe verificarse que el control sigue operando. Valores admitidos: 90, 180, 365.

Criterio de asignación: velocidad con la que el control pierde vigencia sin que nadie lo advierta. NO el nivel del escenario.

90 — listas, permisos y configuraciones que quedan obsoletos solos al cambiar una persona, un proveedor o un sistema.

180 — rutinas operativas: dependen de que alguien las ejecute cada vez y se relajan con la costumbre.

365 — acuerdos firmados, normas familiares, cláusulas contractuales y verificaciones de periodicidad anual por diseño.

fecha_ultima_verificacion — fecha (DD/MM/AAAA) de la última verificación registrada. Vacío = nunca verificado. El formato es el que consume el validador automático.

Vencimiento: fecha_ultima_verificacion + periodicidad_dias < fecha de corte. Un control vencido NO cambia de estado en SGSI-REG-003: sigue IMPLEMENTADO. Lo que decae no es su existencia, sino la acreditación de su eficacia (DOC-004 §6).

VERIFICACIÓN AUTOMÁTICA DE LA REGLA DE CONVERGENCIA:

La regla de convergencia no se comprueba a mano. Las hojas «Registro de riesgos» y «Controles» se exportan a riesgos.csv y controles.csv y se procesan con el validador convergence-check (tool/convergence-check del repositorio del caso), que reproduce literalmente los criterios de esta hoja: regla del máximo, umbrales de nivel, filtro Alto/Crítico, dominios justificados, alcance de las medidas y condiciones de cobertura efectiva.

Diagnósticos: cumple cobertura de dominios aplicables; falta física; falta digital; sin cobertura; evaluación pendiente.

Un resultado favorable no significa riesgo aceptado, cumplimiento normativo ni comprobación del contenido de las evidencias.

por la dirección. Motivo de diseño: una regla que solo se comprueba a mano deja de comprobarse en cuanto el

La exportación y la coherencia SoA-registro se comprueban mediante check_corpus.py; la demostración conserva diferencias simuladas explícitas.

ESTADO DEL SISTEMA A FECHA DE CORTE (24/07/2026):

Controles en estado IMPLEMENTADO: 0 de 64. Controles con verificación registrada: 0 de 64.

En consecuencia, y por aplicación literal de la definición de cobertura efectiva, a esta fecha NINGÚN escenario del registro alcanza cobertura convergente efectiva. Es el resultado esperado de un sistema en implantación cuya primera auditoría está planificada para el primer semestre de 2027.

Dominios del escenario: Ambos, Fisico, Digital o Pendiente, con justificación individual en la columna R.

No se infiere el dominio de un escenario del tipo de controles disponibles; un dominio pendiente no se excluye automáticamente.

La verificación de la regla de convergencia sobre cobertura efectiva se realizará al cierre del plan de tratamiento (SGSI-REG-002) y es entrada obligatoria de la revisión por la dirección (DOC-010 §3.1).

FECHA DE CORTE DEL SISTEMA: 24/07/2026. Toda la documentación del SGSI refleja el estado del sistema en esa fecha. Los plazos de los planes de tratamiento y de la deuda de diseño se cuentan desde ahí.

Aprobación de esta revisión: pendiente. Las referencias históricas a actas describen la ficción; no son evidencias de ejecución publicadas.

Revisión 27/09/2026: C-060 retirado; C-061/C-062/C-064 ORGANIZATIVO; C-065 condicionado. Revisión de HD-02/HD-09/HD-11 y residual pendiente.

El ámbito ORGANIZATIVO sigue siendo necesario. GENERAL significa que la medida no declara una condición que limite su cómputo; no significa eliminar todas las ramas del riesgo. CONDICIONADO y PENDIENTE se informan, no se suman como cobertura general.

La revisión compara diseño y datos. La SoA conserva A.8.14 y los medios físicos preexistentes como excepciones documentadas; no se modifican sus estados para hacer pasar la comprobación.

Registro de riesgos

RSC-001 — Captación de un miembro joven de la familia para obtención de inteligencia

Cadena (resumen): Un antiguo promotor deportivo con una discrepancia económica no resuelta encarga la obtención de información y no actúa en ningún momento → delega en un intermediario del entorno local → el intermediario se hace visible en el entorno frecuentado por el hijo mayor y es este quien busca el contacto → extracción gradual de rutinas, viajes, funcionamiento de la seguridad y vehículos, en encuentros presenciales y por mensajería → vigilancia física de confirmación sobre la finca → aproximación coactiva al principal, con riesgo de derivar en acción sobre la residencia o las personas.

Interfaz: Familia; Entorno social; Físico↔Digital · **Dominios del escenario:** Ambos

Controles existentes: Vigilancia física de la residencia: detectó en el eslabón 5 (vigilancia de confirmación) por reconocimiento de un vehículo apoyado en conocimiento local, no por matrícula ni por análisis. Ningún control en los eslabones 3 y 4. Los eslabones 1 y 2 (encargo y delegación) son inalcanzables para la organización: el instigador no actúa nunca. Es una conclusión del análisis, no una carencia del tratamiento.

I.Per: 4 · **I.Pat:** 3 · **I.Priv:** 3 · **I.Leg:** 2 · **Impacto:** 4 · **Prob.:** 4 · **Nivel:** 16 · **Categoría:** Crítico · **Propietario:** Jefe de seguridad · **Decisión de tratamiento:** Modificar — PT-01 (prioritario) · **Origen:** v1.0

Justificación de dominios: Mensajería y extracción de rutinas; encuentros, vigilancia del perímetro y aproximación coactiva. Ambos dominios aparecen en la cadena.

RSC-002 — Exposición de rutinas en tiempo real por publicaciones de la familia y su entorno

Cadena (resumen): Publicación de ubicaciones y actividades en tiempo real (hijos, entorno, invitados) → reconstrucción de patrones y ausencias → ventana operativa para acción física.

Interfaz: Familia; Entorno social · **Dominios del escenario:** Ambos

Controles existentes: Ninguno: sin normas acordadas ni monitorización.

I.Per: 3 · **I.Pat:** 2 · **I.Priv:** 3 · **I.Leg:** 1 · **Impacto:** 3 · **Prob.:** 4 · **Nivel:** 12 · **Categoría:** Crítico · **Propietario:** Repr. de la propiedad · **Decisión de tratamiento:** Modificar — PT-02 · **Origen:** v1.0

Justificación de dominios: Publicación de ubicación y reconstrucción de patrones digitales habilitan la acción física sobre personas o residencia.

RSC-003 — Compromiso de dispositivo personal de un miembro de la familia

Cadena (resumen): Acceso físico o social al móvil de un miembro de la familia (entorno del hijo, pareja, invitados) → instalación de stalkerware o acceso a cuentas → seguimiento continuo de posición y comunicaciones.

Interfaz: Familia; Entorno social · **Dominios del escenario:** Ambos · **Controles existentes:** Ninguno sobre dispositivos personales. · **I.Per:** 3 · **I.Pat:** 2 · **I.Priv:** 4 · **I.Leg:** 2 · **Impacto:** 4 · **Prob.:** 3 · **Nivel:** 12 · **Categoría:** Crítico · **Propietario:** Jefe de seguridad · **Decisión de tratamiento:** Modificar — PT-03 · **Origen:** v1.0 (P revalorada)

Justificación de dominios: Acceso al dispositivo y custodia física; instalación de software y seguimiento de cuentas y comunicaciones.

RSC-004 — Filtración involuntaria por mensajería personal del círculo de confianza

Cadena (resumen): Miembro del círculo comenta rutinas, viajes o asuntos de la familia por mensajería con su entorno → la información rebota sin control hasta terceros no previstos.

Interfaz: Círculo histórico · **Dominios del escenario:** Ambos · **Controles existentes:** Ninguno: relación sin marco formal. · **I.Per:** 3 · **I.Pat:** 2 · **I.Priv:** 3 · **I.Leg:** 1 · **Impacto:** 3 · **Prob.:** 3 · **Nivel:** 9 · **Categoría:** Alto · **Propietario:** Dirección General · **Decisión de tratamiento:** Modificar — PT-04 · **Origen:** v1.0

Justificación de dominios: Difusión por mensajería de rutinas y desplazamientos que expone la seguridad física; se conserva la relación Digital→Físico ya declarada.

RSC-005 — Compromiso del correo personal del gestor de los asuntos de Irlanda (BEC)

Cadena (resumen): Cuenta de email personal sin MFA usada para asuntos societarios → compromiso por phishing → instrucciones falsas a asesores y entidades irlandesas amparadas en poderes sin revisar.

Interfaz: Círculo histórico; Asesores Dublín · **Dominios del escenario:** Digital

Controles existentes: Ninguno: cuenta personal, poderes de 2015 sin revisar.

I.Per: 1 · **I.Pat:** 4 · **I.Priv:** 3 · **I.Leg:** 2 · **Impacto:** 4 · **Prob.:** 3 · **Nivel:** 12 · **Categoría:** Crítico · **Propietario:** Resp. financiero · **Decisión de tratamiento:** Modificar — PT-05 · **Origen:** v1.0

Justificación de dominios: Compromiso del correo e instrucciones falsas con poderes vigentes. No se describe sustracción o uso material de escrituras en la cadena; su custodia es refuerzo complementario.

RSC-006 — Suplantación de asesor o proveedor para desviar una transferencia

Cadena (resumen): Actor suplanta al despacho de Dublín o a un proveedor recurrente (dominio parecido, cuenta comprometida) → solicita cambio de cuenta o pago urgente → ejecución sin verificación por segundo canal.

Interfaz: Asesores Dublín; Banca privada · **Dominios del escenario:** Digital

Controles existentes: Ninguno: sin verificación de doble canal formalizada.

I.Per: 1 · **I.Pat:** 4 · **I.Priv:** 2 · **I.Leg:** 2 · **Impacto:** 4 · **Prob.:** 3 · **Nivel:** 12 · **Categoría:** Crítico · **Propietario:** Resp. financiero · **Decisión de tratamiento:** Modificar — PT-06 · **Origen:** v1.0

Justificación de dominios: Suplantación por dominio o cuenta y orden de transferencia. La confirmación presencial es una medida de tratamiento condicionada, no un componente físico del ataque descrito.

RSC-007 — Fuga de información fiscal y patrimonial en tránsito

Cadena (resumen): Intercambio semanal España-Irlanda por email sin cifrar → interceptación, reenvío erróneo o compromiso de un buzón → exposición de la posición patrimonial completa.

Interfaz: Asesores Dublín · **Dominios del escenario:** Digital · **Controles existentes:** Ninguno: canal no formalizado. · **I.Per:** 2 · **I.Pat:** 3 · **I.Priv:** 3 · **I.Leg:** 3 · **Impacto:** 3 · **Prob.:** 3 · **Nivel:** 9 · **Categoría:** Alto · **Propietario:** Resp. financiero · **Decisión de tratamiento:** Modificar — PT-06 · **Origen:** v1.0

Justificación de dominios: Intercambio por correo, interceptación, reenvío erróneo o buzón comprometido. No aparece papel ni acceso físico; C-060 no justificaba ese dominio.

RSC-008 — Abuso o compromiso de las cuentas privilegiadas del MSP

Cadena (resumen): Compromiso del MSP o abuso interno de sus técnicos → acceso a correo, NAS, CCTV y domótica sin registro → exfiltración u observación prolongada.

Interfaz: MSP; Físico↔Digital · **Dominios del escenario:** Ambos

Controles existentes: Ninguno: sin MFA exigido, sin registro de sesiones, sin contrato específico.

I.Per: 3 · **I.Pat:** 3 · **I.Priv:** 4 · **I.Leg:** 2 · **Impacto:** 4 · **Prob.:** 2 · **Nivel:** 8 · **Categoría:** Alto · **Propietario:** Jefe de seguridad · **Decisión de tratamiento:** Modificar — PT-07 · **Origen:** v1.0

Justificación de dominios: Acceso administrativo al correo, NAS, CCTV y domótica permite exfiltración y observación prolongada del entorno residencial físico conectado (DOC-001 §7.4).

RSC-009 — Exposición de CCTV y domótica de la residencia a internet

Cadena (resumen): Configuración por defecto de cámaras y domótica → exposición directa o credenciales débiles → observación remota del interior y de rutinas, apertura de accesos.

Interfaz: MSP; Físico↔Digital · **Dominios del escenario:** Ambos

Controles existentes: Vigilancia física (no cubre la capa lógica de sus propios sistemas).

I.Per: 4 · **I.Pat:** 2 · **I.Priv:** 4 · **I.Leg:** 2 · **Impacto:** 4 · **Prob.:** 3 · **Nivel:** 12 · **Categoría:** Crítico · **Propietario:** Jefe de seguridad · **Decisión de tratamiento:** Modificar — PT-07 · **Origen:** v1.0

Justificación de dominios: Exposición lógica de cámaras/domótica; observación del interior y apertura de accesos físicos.

RSC-010 — Suplantación del principal ante la banca mediante voz sintética

Cadena (resumen): Cientos de horas de voz pública del principal → clonación de voz → llamada a banca o a la asistente ordenando disposición urgente → ejecución sin verificación.

Interfaz: Banca privada; Familia · **Dominios del escenario:** Digital

Controles existentes: Ninguno: la voz funciona hoy como factor de confianza de facto.

I.Per: 1 · **I.Pat:** 4 · **I.Priv:** 2 · **I.Leg:** 1 · **Impacto:** 4 · **Prob.:** 2 · **Nivel:** 8 · **Categoría:** Alto · **Propietario:** Resp. financiero · **Decisión de tratamiento:** Modificar — PT-06 · **Origen:** v1.0

Justificación de dominios: Clonación de voz y llamada para obtener una disposición. No se describe acceso físico del atacante; la presencia exigida desde 50.000 euros pertenece al tratamiento.

RSC-011 — Copia de información por acceso físico no controlado en la residencia

Cadena (resumen): Personal doméstico, contratas o invitados con acceso no acompañado → copia de documentos, fotografía de pantallas y llaves, acceso al NAS por la red común.

Interfaz: Servicios contratados; Contratas y trabajos; Físico↔Digital

Dominios del escenario: Ambos

Controles existentes: Control de entrada a la finca; nada dentro (red única, soportes sin proteger).

I.Per: 3 · **I.Pat:** 3 · **I.Priv:** 3 · **I.Leg:** 2 · **Impacto:** 3 · **Prob.:** 4 · **Nivel:** 12 · **Categoría:** Crítico · **Propietario:** Jefe de seguridad · **Decisión de tratamiento:** Modificar — PT-08 · **Origen:** v1.0 (P revalorada)

Justificación de dominios: Acceso no acompañado a la residencia, documentos y llaves; fotografía de pantallas y acceso al NAS por la red común.

RSC-012 — Pérdida o robo de dispositivo en viaje con información sin cifrar

Cadena (resumen): Dispositivo habitual viaja con información Confidencial/Restringida sin cifrar → pérdida o sustracción → acceso directo a agenda, documentos y credenciales.

Interfaz: Familia; Proveedores de viaje · **Dominios del escenario:** Ambos

Controles existentes: Ninguno: sin cifrado verificado ni borrado remoto.

I.Per: 3 · **I.Pat:** 3 · **I.Priv:** 3 · **I.Leg:** 2 · **Impacto:** 3 · **Prob.:** 3 · **Nivel:** 9 · **Categoría:** Alto · **Propietario:** Jefe de seguridad · **Decisión de tratamiento:** Modificar — PT-09 · **Origen:** v1.0

Justificación de dominios: Pérdida o sustracción física del dispositivo y acceso a información digital sin cifrar.

RSC-013 — Ransomware o pérdida del servidor y NAS

Cadena (resumen): Phishing a un empleado o vulnerabilidad sin parchear → cifrado del servidor de la oficina y del NAS doméstico → pérdida de disponibilidad y posible exfiltración.

Interfaz: MSP · **Dominios del escenario:** Digital

Controles existentes: Antivirus básico; copias sin verificar gestionadas por el MSP.

I.Per: 1 · **I.Pat:** 3 · **I.Priv:** 3 · **I.Leg:** 2 · **Impacto:** 3 · **Prob.:** 3 · **Nivel:** 9 · **Categoría:** Alto · **Propietario:** Dirección General · **Decisión de tratamiento:** Modificar — PT-10 · **Origen:** v1.0

Justificación de dominios: Phishing o vulnerabilidad, cifrado de servidor/NAS y exfiltración. No se describe destrucción ni sustracción física; la custodia de copias es defensa complementaria.

RSC-014 — Abuso o coacción de la identidad digital delegada del principal

Cadena (resumen): La asistente personal concentra correo, firmas y credenciales del principal → compromiso de su puesto, coacción o suplantación interna → actos de disposición no autorizados.

Interfaz: Banca privada; Familia · **Dominios del escenario:** Pendiente

Controles existentes: Confianza personal; sin registro de actos por delegación.

I.Per: 2 · **I.Pat:** 4 · **I.Priv:** 3 · **I.Leg:** 2 · **Impacto:** 4 · **Prob.:** 2 · **Nivel:** 8 · **Categoría:** Alto · **Propietario:** Dirección General · **Decisión de tratamiento:** Modificar — PT-06 · **Origen:** v1.0

Justificación de dominios: La cadena acredita compromiso de puesto y abuso de identidad digital, pero no concreta el medio de coacción. El componente físico debe precisarse antes de excluirlo o acreditarlo; no se amplía el escenario.

RSC-015 — Agregación OSINT del patrimonio y señalamiento público

Cadena (resumen): Registros públicos, prensa histórica y RRSS agregados → perfil patrimonial y de ubicaciones reconstruido → focalización por actores oportunistas.

Interfaz: Familia · **Dominios del escenario:** Ambos

Controles existentes: Ninguno: sin línea base OSINT ni vigilancia de exposición.

I.Per: 3 · **I.Pat:** 2 · **I.Priv:** 3 · **I.Leg:** 1 · **Impacto:** 3 · **Prob.:** 4 · **Nivel:** 12 · **Categoría:** Crítico · **Propietario:** Repr. de la propiedad · **Decisión de tratamiento:** Modificar — PT-02 · **Origen:** v1.0 (P revalorada)

Justificación de dominios: Agregación digital de patrimonio y ubicaciones para el señalamiento y aproximación sobre personas o emplazamientos físicos ya declarados.

RSC-016 — Envío de información confidencial a destinatario erróneo

Cadena (resumen): Volumen de intercambios con asesores y banca sin plantillas ni doble comprobación → autocompletado o error humano → información Confidencial a un tercero.

Interfaz: Asesores Dublín; Banca privada · **Dominios del escenario:** Digital · **Controles existentes:** Ninguno específico. · **I.Per:** 1 · **I.Pat:** 2 · **I.Priv:** 2 · **I.Leg:** 2 · **Impacto:** 2 · **Prob.:** 3 · **Nivel:** 6 · **Categoría:** Alto · **Propietario:** Dirección General · **Decisión de tratamiento:** Modificar — PT-06 · **Origen:** v1.0

Justificación de dominios: Autocompletado y error de destinatario en intercambios con banca y asesores. No se describe soporte o eslabón físico.

RSC-017 — Indisponibilidad temporal de servicios cloud (M365)

Cadena (resumen): Caída del proveedor cloud → indisponibilidad de correo y documentos durante horas → impacto operativo sin exposición de información.

Interfaz: MSP · **Dominios del escenario:** Digital · **Controles existentes:** Redundancia del propio proveedor. · **I.Per:** 1 · **I.Pat:** 2 · **I.Priv:** 1 · **I.Leg:** 1 · **Impacto:** 2 · **Prob.:** 2 · **Nivel:** 4 · **Categoría:** Moderado · **Propietario:** Dirección General

Decisión de tratamiento: Retener — aceptado con justificación (DOC-004 §4.4)

Origen: v1.0

Justificación de dominios: Caída de servicios de correo y documentos del proveedor. No hay daño físico descrito. Nivel Moderado: fuera del filtro Alto/Crítico, no fuera del SGSI.

RSC-018 — Inejecución sistemática de los controles físicos existentes de la residencia

Cadena (resumen): Alarma perimetral no conectada al cierre, ventanas y accesos secundarios abiertos, vigilante distraído en conversación prolongada → el perímetro declarado no existe en la práctica durante ventanas recurrentes y previsibles → intrusión o aproximación sin detección.

Interfaz: Servicios contratados; Físico↔Digital · **Dominios del escenario:** Ambos

Controles existentes: Alarma, CCTV y vigilancia contratadas y operativas, pero sin verificación de ejecución ni registro de cumplimiento.

I.Per: 4 · **I.Pat:** 3 · **I.Priv:** 3 · **I.Leg:** 1 · **Impacto:** 4 · **Prob.:** 4 · **Nivel:** 16 · **Categoría:** Crítico · **Propietario:** Jefe de seguridad · **Decisión de tratamiento:** Modificar — PT-11 (prioritario) · **Origen:** v1.1 — NUEVO

Justificación de dominios: Aberturas, rondas y perímetro físicos; armado y supervisión técnica de alarma/CCTV conectados ya descritos en el caso.

RSC-019 — Transporte y entrega de efectivo y valores en mano sin protocolo

Cadena (resumen): Disposición de efectivo o valores movida físicamente por el principal o una persona de confianza, sin doble validación, sin ruta variable y sin registro → el portador se convierte en objetivo señalado y un desvío o pérdida no es reconstruible a posteriori.

Interfaz: Banca privada; Familia · **Dominios del escenario:** Fisico

Controles existentes: Ninguno: la práctica se sostiene solo en la confianza personal en el portador.

I.Per: 4 · **I.Pat:** 4 · **I.Priv:** 2 · **I.Leg:** 3 · **Impacto:** 4 · **Prob.:** 3 · **Nivel:** 12 · **Categoría:** Crítico · **Propietario:** Resp. financiero · **Decisión de tratamiento:** Modificar — PT-12 (prioritario) · **Origen:** v1.1 — NUEVO

Justificación de dominios: Transporte y entrega material de efectivo/valores, portador y ruta. El procedimiento y la trazabilidad en papel no introducen por sí solos un dominio digital.

RSC-020 — Acceso de obras, reparaciones y contratas sin planificación ni acreditación

Cadena (resumen): Trabajos contratados sin preaviso, sin lista nominal, sin acompañamiento ni control de horario → personas desconocidas circulando por zonas sensibles de la residencia → reconocimiento interior, copia de llaves, colocación de dispositivos o simple filtración de lo visto.

Interfaz: Contratas y trabajos; Físico↔Digital · **Dominios del escenario:** Ambos

Controles existentes: Control de entrada a la finca sin identificación nominal ni acreditación previa.

I.Per: 3 · **I.Pat:** 3 · **I.Priv:** 3 · **I.Leg:** 2 · **Impacto:** 3 · **Prob.:** 4 · **Nivel:** 12 · **Categoría:** Crítico · **Propietario:** Jefe de seguridad · **Decisión de tratamiento:** Modificar — PT-13 · **Origen:** v1.1 — NUEVO

Justificación de dominios: Entrada y circulación de contratas en zonas sensibles; la cadena incluye colocación de dispositivos, con exposición físico-digital ya declarada en la interfaz. No se presume eficacia del registro en papel como medida digital.

RSC-021 — Introducción de terceros desconocidos en la residencia por los hijos

Cadena (resumen): Los hijos invitan a personas no verificadas sin aviso previo → acceso a zonas interiores, observación de rutinas y de la disposición de la casa → vía de aproximación de un actor hostil bajo apariencia de relación social.

Interfaz: Familia; Entorno social; Físico↔Digital · **Dominios del escenario:** Fisico

Controles existentes: Ninguno: no existe norma de aviso ni verificación de invitados.

I.Per: 4 · **I.Pat:** 3 · **I.Priv:** 3 · **I.Leg:** 1 · **Impacto:** 4 · **Prob.:** 4 · **Nivel:** 16 · **Categoría:** Crítico · **Propietario:** Repr. de la propiedad · **Decisión de tratamiento:** Modificar — PT-13 · **Origen:** v1.1 — NUEVO

Justificación de dominios: Invitación y acceso presencial de terceros, observación del interior y aproximación social. El sistema digital de registro de visitas es tratamiento complementario; no se introduce un ataque digital en la cadena.

RSC-022 — Ausencia de preparación de seguridad en destino durante los desplazamientos

Cadena (resumen): Viajes decididos y reservados sin evaluación previa del destino, del alojamiento ni de los servicios locales → llegada a un entorno desconocido con itinerario ya difundido entre terceros → exposición de las personas fuera del perímetro protegido.

Interfaz: Familia; Proveedores de viaje · **Dominios del escenario:** Ambos

Controles existentes: Ninguno: la seguridad en viaje se improvisa en destino.

I.Per: 4 · **I.Pat:** 2 · **I.Priv:** 2 · **I.Leg:** 1 · **Impacto:** 4 · **Prob.:** 3 · **Nivel:** 12 · **Categoría:** Crítico · **Propietario:** Jefe de seguridad · **Decisión de tratamiento:** Modificar — PT-09 · **Origen:** v1.1 — NUEVO

Justificación de dominios: Exposición física en destino y difusión del itinerario entre proveedores, por los canales de agenda y comunicaciones del alcance y DOC-008. No se añaden plataformas.

RSC-023 — Documentación patrimonial en papel dispersa y sin control

Cadena (resumen): Documentación societaria, fiscal y patrimonial correcta pero conservada en papel, repartida entre oficina y residencia, sin inventario, sin custodia y sin control de acceso → visible o sustraíble por cualquiera que entre, y no se puede saber qué falta.

Interfaz: Servicios contratados; Contratas y trabajos · **Dominios del escenario:** Fisico

Controles existentes: Ninguno: no hay inventario documental ni custodia definida.

I.Per: 1 · **I.Pat:** 3 · **I.Priv:** 3 · **I.Leg:** 3 · **Impacto:** 3 · **Prob.:** 4 · **Nivel:** 12 · **Categoría:** Crítico · **Propietario:** Dirección General · **Decisión de tratamiento:** Modificar — PT-14 · **Origen:** v1.1 — NUEVO

Justificación de dominios: Papel disperso, visible y sustraíble en oficina/residencia. La digitalización prevista es una opción de tratamiento, no un componente digital del escenario inicial.

RSC-024 — Obsolescencia técnica del proveedor informático de referencia

Cadena (resumen): El proveedor habitual mantiene los sistemas con criterios desactualizados y desconoce las amenazas y medidas actuales → decisiones técnicas por defecto, sin línea base ni endurecimiento → vulnerabilidades persistentes que nadie identifica porque nadie las busca.

Interfaz: MSP · **Dominios del escenario:** Digital

Controles existentes: Servicio contratado y operativo, sin verificación independiente de su criterio técnico.

I.Per: 1 · **I.Pat:** 3 · **I.Priv:** 3 · **I.Leg:** 2 · **Impacto:** 3 · **Prob.:** 3 · **Nivel:** 9 · **Categoría:** Alto · **Propietario:** Dirección General · **Decisión de tratamiento:** Modificar — PT-15 · **Origen:** v1.1 — NUEVO

Justificación de dominios: Decisiones de configuración desactualizadas y vulnerabilidades técnicas. El inventario de equipos no prueba un eslabón físico de ataque.

RSC-025 — Exposición de la familia en desplazamientos rutinarios por fallos de coordinación

Cadena (resumen): Retrasos recurrentes del servicio de conducción → la familia espera en punto fijo, previsible y sin cobertura durante períodos prolongados → ventana de aproximación, observación o acción directa sobre las personas.

Interfaz: Familia; Servicios contratados · **Dominios del escenario:** Fisico

Controles existentes: Servicio de conducción contratado, sin protocolo de puntualidad, punto de espera ni aviso.

I.Per: 4 · **I.Pat:** 2 · **I.Priv:** 1 · **I.Leg:** 1 · **Impacto:** 4 · **Prob.:** 3 · **Nivel:** 12 · **Categoría:** Crítico · **Propietario:** Jefe de seguridad · **Decisión de tratamiento:** Modificar — PT-16 · **Origen:** v1.1 — NUEVO

Justificación de dominios: Retraso del conductor, espera en punto fijo y aproximación a personas. La geolocalización prevista es una medida digital complementaria, no un fallo digital descrito en la cadena.

Controles

C-001 — RSC-001

Descripción del control: Acuerdo familiar de exposición pública firmado, con reglas concretas sobre qué no se publica

Eslabón que rompe: Eslabón 3 — aproximación al hijo mayor · **dominio:** ORGANIZATIVO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Repr. de la propiedad · **ref_27002:** 6.3, 5.10 · **periodicidad_dias:** 365 · **fecha_ultima_verificacion:** — · **Plan:** PT-01 · **alcance_cobertura:** GENERAL · **condicion:** —

C-002 — RSC-001

Descripción del control: Canal de comunicación de contactos sospechosos accesible a los hijos, sin sanción asociada

Eslabón que rompe: Eslabón 3 — aproximación al hijo mayor · **dominio:** ORGANIZATIVO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Repr. de la propiedad · **ref_27002:** 5.24, 6.8 · **periodicidad_dias:** 365 · **fecha_ultima_verificacion:** — · **Plan:** PT-01 · **alcance_cobertura:** GENERAL · **condicion:** —

C-003 — RSC-001

Descripción del control: Cuaderno de indicios con revisión semanal conjunta de observaciones físicas y digitales

Eslabón que rompe: Eslabón 5 — vigilancia de confirmación · **dominio:** ORGANIZATIVO · **estado:** PARCIAL

evidencia: EV-2026-001

propietario_control: Jefe de seguridad · **ref_27002:** 5.25 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-01 · **alcance_cobertura:** GENERAL · **condicion:** —

C-004 — RSC-001

Descripción del control: Registro nominal de vehículos y personas observadas en el entorno de la finca

Eslabón que rompe: Eslabón 5 — vigilancia de confirmación · **dominio:** FISICO · **estado:** PARCIAL

evidencia: EV-2026-002

propietario_control: Jefe de seguridad · **ref_27002:** 7.4 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-01 · **alcance_cobertura:** GENERAL · **condicion:** —

C-005 — RSC-001

Descripción del control: Configuración de privacidad y revisión periódica de las cuentas públicas de los hijos

Eslabón que rompe: Eslabón 3 — aproximación al hijo mayor · **dominio:** DIGITAL · **estado:** PLANIFICADO

evidencia: —

propietario_control: Repr. de la propiedad · **ref_27002:** 5.10 · **periodicidad_dias:** 90 · **fecha_ultima_verificacion:** — · **Plan:** PT-01 · **alcance_cobertura:** GENERAL · **condicion:** —

C-006 — RSC-002

Descripción del control: Publicación diferida acordada: ningún contenido que revele ubicación se publica hasta haber abandonado esa ubicación (DOC-008 §3)

Eslabón que rompe: Eslabón 1 — señal en tiempo real · **dominio:** ORGANIZATIVO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Repr. de la propiedad · **ref_27002:** 5.10 · **periodicidad_dias:** 365 · **fecha_ultima_verificacion:** — · **Plan:** PT-02 · **alcance_cobertura:** GENERAL · **condicion:** —

C-007 — RSC-002

Descripción del control: Línea base OSINT y revisión trimestral de la exposición pública de la familia

Eslabón que rompe: Eslabón 2 — reconstrucción de patrones · **dominio:** DIGITAL · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 5.7 · **periodicidad_dias:** 90 · **fecha_ultima_verificacion:** — · **Plan:** PT-02 · **alcance_cobertura:** GENERAL · **condicion:** —

C-008 — RSC-002

Descripción del control: Regla de discreción en accesos y salidas de la finca para personal e invitados

Eslabón que rompe: Eslabón 3 — confirmación de ausencias · **dominio:** FISICO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 7.2 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-02 · **alcance_cobertura:** GENERAL · **condicion:** —

C-009 — RSC-003

Descripción del control: Configuración segura y revisión periódica de dispositivos familiares, con consentimiento

Eslabón que rompe: Eslabón 2 — instalación de software · **dominio:** DIGITAL · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 8.1 · **periodicidad_dias:** 90 · **fecha_ultima_verificacion:** — · **Plan:** PT-03 · **alcance_cobertura:** GENERAL · **condicion:** —

C-010 — RSC-003

Descripción del control: Pauta de custodia física del dispositivo: no se deja desatendido ni se presta

Eslabón que rompe: Eslabón 1 — acceso físico al terminal · **dominio:** FISICO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Repr. de la propiedad · **ref_27002:** 7.9 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-03 · **alcance_cobertura:** GENERAL · **condicion:** —

C-011 — RSC-004

Descripción del control: Acuerdos personales de confianza ACU-001/002 con ejemplos concretos de lo que no sale de la casa

Eslabón que rompe: Eslabón 1 — comentario informal · **dominio:** ORGANIZATIVO · **estado:** PARCIAL

evidencia: EV-2026-003

propietario_control: Dirección General · **ref_27002:** 6.6 · **periodicidad_dias:** 365 · **fecha_ultima_verificacion:** — · **Plan:** PT-04 · **alcance_cobertura:** GENERAL · **condicion:** —

C-012 — RSC-004

Descripción del control: Canal único y trazable para asuntos de la familia con el círculo histórico

Eslabón que rompe: Eslabón 2 — difusión incontrolada · **dominio:** DIGITAL · **estado:** PLANIFICADO

evidencia: —

propietario_control: Dirección General · **ref_27002:** 5.14 · **periodicidad_dias:** 365 · **fecha_ultima_verificacion:** — · **Plan:** PT-04 · **alcance_cobertura:** GENERAL · **condicion:** —

C-013 — RSC-005

Descripción del control: Revisión y acotación de los poderes notariales de 2015 con asesoría legal

Eslabón que rompe: Eslabón 3 — instrucciones falsas amparadas en poderes sin revisar

dominio: ORGANIZATIVO · **estado:** PARCIAL

evidencia: EV-2026-004

propietario_control: Resp. financiero · **ref_27002:** 5.18 · **periodicidad_dias:** 365 · **fecha_ultima_verificacion:** — · **Plan:** PT-05 · **alcance_cobertura:** GENERAL · **condicion:** —

C-014 — RSC-005

Descripción del control: Cuenta corporativa nominal con MFA para todo asunto societario; fin del correo personal

Eslabón que rompe: Eslabón 2 — compromiso de la cuenta · **dominio:** DIGITAL · **estado:** PLANIFICADO

evidencia: —

propietario_control: Resp. financiero · **ref_27002:** 5.16, 5.17 · **periodicidad_dias:** 90 · **fecha_ultima_verificacion:** — · **Plan:** PT-05 · **alcance_cobertura:** GENERAL · **condicion:** —

C-015 — RSC-006

Descripción del control: Verificación por segundo canal contra contacto prerregistrado para órdenes ≥10.000 € y cambios de beneficiario sin umbral; circuito reforzado del principal conforme a DOC-007 §4

Eslabón que rompe: Eslabón 3 — ejecución de la orden · **dominio:** ORGANIZATIVO · **estado:** PARCIAL

evidencia: EV-2026-005

propietario_control: Resp. financiero · **ref_27002:** 5.14, 8.5 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-06 · **alcance_cobertura:** GENERAL · **condicion:** —

C-016 — RSC-006

Descripción del control: Lista de contactos verificados de asesores y proveedores, bajo custodia y revisión semestral

Eslabón que rompe: Eslabón 2 — suplantación de identidad · **dominio:** DIGITAL · **estado:** PLANIFICADO

evidencia: —

propietario_control: Resp. financiero · **ref_27002:** 5.14 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-06 · **alcance_cobertura:** PENDIENTE

condicion: C-016: lista de contactos; falta acreditar mecanismo digital. No basta el soporte o la etiqueta.

C-017 — RSC-007

Descripción del control: Canal cifrado acordado con el despacho de Dublín para todo intercambio patrimonial

Eslabón que rompe: Eslabón 2 — tránsito de la información · **dominio:** DIGITAL · **estado:** PLANIFICADO

evidencia: —

propietario_control: Resp. financiero · **ref_27002:** 5.14, 8.24 · **periodicidad_dias:** 365 · **fecha_ultima_verificacion:** — · **Plan:** PT-06 · **alcance_cobertura:** GENERAL · **condicion:** —

C-018 — RSC-010

Descripción del control: La voz no autentica: regla escrita y comunicada a banca y asistente

Eslabón que rompe: Eslabón 3 — autorización de la orden · **dominio:** ORGANIZATIVO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Resp. financiero · **ref_27002:** 5.17 · **periodicidad_dias:** 365 · **fecha_ultima_verificacion:** — · **Plan:** PT-06 · **alcance_cobertura:** GENERAL · **condicion:** —

C-019 — RSC-014

Descripción del control: Registro de actos ejecutados por delegación, con revisión mensual por la Dirección General

Eslabón que rompe: Eslabón 3 — acto de disposición · **dominio:** DIGITAL · **estado:** PLANIFICADO

evidencia: —

propietario_control: Dirección General · **ref_27002:** 5.18, 8.15 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-06 · **alcance_cobertura:** PENDIENTE

condicion: C-019: registro de actos; falta acreditar mecanismo digital de trazabilidad. No se presume por el nombre.

C-020 — RSC-016

Descripción del control: Plantillas y doble comprobación de destinatario para envíos con información Confidencial

Eslabón que rompe: Eslabón 2 — error humano · **dominio:** ORGANIZATIVO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Dirección General · **ref_27002:** 5.14 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-06 · **alcance_cobertura:** GENERAL · **condicion:** —

C-021 — RSC-008

Descripción del control: Anexo contractual con el MSP: MFA obligatorio, cuentas nominales, registro de sesiones 12 meses

Eslabón que rompe: Eslabón 1 — acceso privilegiado · **dominio:** DIGITAL · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 5.20, 5.22, 8.2, 8.18 · **periodicidad_dias:** 365 · **fecha_ultima_verificacion:** — · **Plan:** PT-07 · **alcance_cobertura:** GENERAL · **condicion:** —

C-022 — RSC-008

Descripción del control: Custodia física del armario de comunicaciones y registro de accesos al mismo

Eslabón que rompe: Eslabón 2 — acceso a la infraestructura · **dominio:** FISICO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 7.4, 7.8, 7.12 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-07 · **alcance_cobertura:** GENERAL · **condicion:** —

C-023 — RSC-009

Descripción del control: Segmentación de red: CCTV y domótica fuera de la red de datos, sin exposición a internet

Eslabón que rompe: Eslabón 1 — exposición del sistema · **dominio:** DIGITAL · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 8.20, 8.22 · **periodicidad_dias:** 90 · **fecha_ultima_verificacion:** — · **Plan:** PT-07 · **alcance_cobertura:** GENERAL · **condicion:** —

C-024 — RSC-009

Descripción del control: Control de acceso al grabador y a la sala técnica; registro de quién consulta grabaciones

Eslabón que rompe: Eslabón 3 — acceso a las imágenes · **dominio:** FISICO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 7.4, 8.15 · **periodicidad_dias:** 90 · **fecha_ultima_verificacion:** — · **Plan:** PT-07 · **alcance_cobertura:** GENERAL · **condicion:** —

C-025 — RSC-011

Descripción del control: Zonificación interior de la residencia y regla de acompañamiento por zonas

Eslabón que rompe: Eslabón 1 — acceso no acompañado · **dominio:** FISICO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 7.2, 7.6 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-08 · **alcance_cobertura:** GENERAL · **condicion:** —

C-026 — RSC-011

Descripción del control: Red separada para invitados y personal, sin acceso al NAS ni a los sistemas de la oficina

Eslabón que rompe: Eslabón 2 — acceso al NAS por la red común · **dominio:** DIGITAL · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 8.22, 8.3 · **periodicidad_dias:** 90 · **fecha_ultima_verificacion:** — · **Plan:** PT-08 · **alcance_cobertura:** GENERAL · **condicion:** —

C-027 — RSC-012

Descripción del control: Cifrado y borrado remoto verificados antes de cada salida, con registro de la verificación

Eslabón que rompe: Eslabón 2 — acceso al contenido · **dominio:** DIGITAL · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 8.24, 8.1 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-09 · **alcance_cobertura:** GENERAL · **condicion:** —

C-028 — RSC-012

Descripción del control: Dotación de viaje diferenciada: equipo limpio para destinos de riesgo

Eslabón que rompe: Eslabón 1 — exposición del soporte · **dominio:** FISICO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 7.9 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-09 · **alcance_cobertura:** GENERAL · **condicion:** —

C-029 — RSC-022

Descripción del control: Ficha de seguridad de destino previa a la reserva: alojamiento, entorno, servicios y contactos locales

Eslabón que rompe: Eslabón 1 — decisión del viaje · **dominio:** ORGANIZATIVO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 5.7, 6.7 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-09 · **alcance_cobertura:** GENERAL · **condicion:** —

C-030 — RSC-022

Descripción del control: Reconocimiento previo o contacto con servicio local en destinos de riesgo alto

Eslabón que rompe: Eslabón 3 — llegada al destino · **dominio:** FISICO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 7.1, 7.4 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-09 · **alcance_cobertura:** GENERAL · **condicion:** —

C-031 — RSC-022

Descripción del control: Restricción de difusión del itinerario: lista cerrada de destinatarios y sin publicación previa

Eslabón que rompe: Eslabón 2 — difusión del itinerario · **dominio:** DIGITAL · **estado:** PLANIFICADO

evidencia: —

propietario_control: Repr. de la propiedad · **ref_27002:** 5.12, 5.14 · **periodicidad_dias:** 90 · **fecha_ultima_verificacion:** — · **Plan:** PT-09 · **alcance_cobertura:** GENERAL · **condicion:** —

C-032 — RSC-013

Descripción del control: Copias 3-2-1 con una copia fuera de línea y prueba de restauración semestral documentada

Eslabón que rompe: Eslabón 3 — pérdida de disponibilidad · **dominio:** DIGITAL · **estado:** PLANIFICADO

evidencia: —

propietario_control: Dirección General · **ref_27002:** 8.13, 5.30 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-10 · **alcance_cobertura:** GENERAL · **condicion:** —

C-033 — RSC-013

Descripción del control: Custodia física de la copia fuera de línea en ubicación distinta a la oficina

Eslabón que rompe: Eslabón 3 — pérdida de disponibilidad · **dominio:** FISICO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Dirección General · **ref_27002:** 7.10, 8.13, 5.30 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-10 · **alcance_cobertura:** GENERAL · **condicion:** —

C-034 — RSC-018

Descripción del control: Lista de verificación de cierre firmada al final de cada jornada: alarma conectada y aberturas comprobadas

Eslabón que rompe: Eslabón 1 — ventana de inejecución · **dominio:** ORGANIZATIVO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 5.36, 5.37 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-11 · **alcance_cobertura:** GENERAL · **condicion:** —

C-035 — RSC-018

Descripción del control: Contactos de apertura en aberturas secundarias, integrados en la señal de armado del sistema

Eslabón que rompe: Eslabón 1 — ventana de inejecución · **dominio:** FISICO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 7.1, 7.4 · **periodicidad_dias:** 90 · **fecha_ultima_verificacion:** — · **Plan:** PT-11 · **alcance_cobertura:** GENERAL · **condicion:** —

C-036 — RSC-018

Descripción del control: Supervisión técnica del armado: registro automático de conexión y desconexión, con alerta si no se arma

Eslabón que rompe: Eslabón 2 — ausencia de detección · **dominio:** DIGITAL · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 8.15, 8.16 · **periodicidad_dias:** 90 · **fecha_ultima_verificacion:** — · **Plan:** PT-11 · **alcance_cobertura:** GENERAL · **condicion:** —

C-037 — RSC-018

Descripción del control: Rondas con puntos de paso registrados y revisión mensual de cumplimiento

Eslabón que rompe: Eslabón 2 — ausencia de detección · **dominio:** FISICO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 7.4 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-11 · **alcance_cobertura:** GENERAL · **condicion:** —

C-038 — RSC-019

Descripción del control: Doble validación de toda disposición de efectivo por encima del umbral, con registro previo

Eslabón que rompe: Eslabón 1 — decisión de la disposición · **dominio:** ORGANIZATIVO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Resp. financiero · **ref_27002:** 5.3, 8.5 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-12 · **alcance_cobertura:** GENERAL · **condicion:** —

C-039 — RSC-019

Descripción del control: Trazabilidad del movimiento: albarán o registro firmado en origen y destino, conciliado en 24 horas

Eslabón que rompe: Eslabón 2 — pérdida o desvío no reconstruible · **dominio:** ORGANIZATIVO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Resp. financiero · **ref_27002:** 5.33 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-12 · **alcance_cobertura:** GENERAL · **condicion:** —

C-040 — RSC-019

Descripción del control: Protocolo de transporte: portador rotatorio, ruta y horario variables, acompañamiento por encima del umbral

Eslabón que rompe: Eslabón 1 — movimiento físico sin ruta variable · **dominio:** FISICO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 7.10, 7.9 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-12 · **alcance_cobertura:** GENERAL · **condicion:** —

C-041 — RSC-019

Descripción del control: Clasificación Restringida de la existencia y el calendario de los movimientos; difusión mínima

Eslabón que rompe: Eslabón 2 — conocimiento del movimiento · **dominio:** ORGANIZATIVO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Resp. financiero · **ref_27002:** 5.12 · **periodicidad_dias:** 365 · **fecha_ultima_verificacion:** — · **Plan:** PT-12 · **alcance_cobertura:** GENERAL · **condicion:** —

C-042 — RSC-020

Descripción del control: Planificación previa obligatoria de todo trabajo: lista nominal, fechas, horario y alcance

Eslabón que rompe: Eslabón 1 — alta del acceso · **dominio:** ORGANIZATIVO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 5.19, 5.20 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-13 · **alcance_cobertura:** GENERAL · **condicion:** —

C-043 — RSC-020

Descripción del control: Acreditación nominal con identificación verificada y acompañamiento en zonas sensibles

Eslabón que rompe: Eslabón 2 — circulación interior · **dominio:** FISICO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 7.2, 7.6 · **periodicidad_dias:** 90 · **fecha_ultima_verificacion:** — · **Plan:** PT-13 · **alcance_cobertura:** GENERAL · **condicion:** —

C-044 — RSC-020

Descripción del control: Registro de entradas y salidas de contratas, conservado y revisado mensualmente

Eslabón que rompe: Eslabón 3 — ausencia de rastro · **dominio:** ORGANIZATIVO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 7.2, 5.33 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-13 · **alcance_cobertura:** GENERAL · **condicion:** —

C-045 — RSC-021

Descripción del control: Norma de aviso previo de invitados acordada con los hijos, con nombre y hora

Eslabón que rompe: Eslabón 1 — introducción del tercero · **dominio:** ORGANIZATIVO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Repr. de la propiedad · **ref_27002:** 5.10, 6.3 · **periodicidad_dias:** 365 · **fecha_ultima_verificacion:** — · **Plan:** PT-13 · **alcance_cobertura:** GENERAL · **condicion:** —

C-046 — RSC-021

Descripción del control: Zona social delimitada para visitas no verificadas, sin acceso al resto de la residencia

Eslabón que rompe: Eslabón 2 — acceso a zonas sensibles · **dominio:** FISICO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 7.2, 7.3 · **periodicidad_dias:** 365 · **fecha_ultima_verificacion:** — · **Plan:** PT-13 · **alcance_cobertura:** GENERAL · **condicion:** —

C-047 — RSC-021

Descripción del control: Registro de visitas en el sistema de acceso y cruce semanal con el cuaderno de indicios

Eslabón que rompe: Eslabón 3 — ausencia de correlación · **dominio:** DIGITAL · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 7.2, 5.25 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-13 · **alcance_cobertura:** GENERAL · **condicion:** —

C-048 — RSC-023

Descripción del control: Inventario documental con ubicación, responsable y plazo de conservación de cada serie

Eslabón que rompe: Eslabón 1 — dispersión sin control · **dominio:** ORGANIZATIVO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Dirección General · **ref_27002:** 5.9, 5.33 · **periodicidad_dias:** 90 · **fecha_ultima_verificacion:** — · **Plan:** PT-14 · **alcance_cobertura:** GENERAL · **condicion:** —

C-049 — RSC-023

Descripción del control: Custodia en armario ignífugo con llave controlada; retirada del papel de zonas comunes

Eslabón que rompe: Eslabón 2 — acceso al soporte · **dominio:** FISICO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Dirección General · **ref_27002:** 7.10, 7.7 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-14 · **alcance_cobertura:** GENERAL · **condicion:** —

C-050 — RSC-023

Descripción del control: Digitalización con clasificación y control de acceso por rol; destrucción certificada del papel redundante

Eslabón que rompe: Eslabón 2 — imposibilidad de saber qué falta · **dominio:** DIGITAL · **estado:** PLANIFICADO

evidencia: —

propietario_control: Dirección General · **ref_27002:** 5.12, 5.15, 7.10 · **periodicidad_dias:** 90 · **fecha_ultima_verificacion:** — · **Plan:** PT-14 · **alcance_cobertura:** GENERAL · **condicion:** —

C-051 — RSC-024

Descripción del control: Verificación técnica independiente anual del criterio y la configuración del MSP

Eslabón que rompe: Eslabón 2 — decisiones por defecto · **dominio:** ORGANIZATIVO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Dirección General · **ref_27002:** 5.35, 5.22 · **periodicidad_dias:** 365 · **fecha_ultima_verificacion:** — · **Plan:** PT-15 · **alcance_cobertura:** GENERAL · **condicion:** —

C-052 — RSC-024

Descripción del control: Línea base de configuración documentada y contrastada, revisada tras cada cambio relevante

Eslabón que rompe: Eslabón 1 — ausencia de criterio · **dominio:** DIGITAL · **estado:** PLANIFICADO

evidencia: —

propietario_control: Dirección General · **ref_27002:** 8.9, 8.8, 5.23, 8.32 · **periodicidad_dias:** 90 · **fecha_ultima_verificacion:** — · **Plan:** PT-15 · **alcance_cobertura:** GENERAL · **condicion:** —

C-053 — RSC-025

Descripción del control: Protocolo de puntualidad y aviso: confirmación de posición 15 minutos antes de cada recogida

Eslabón que rompe: Eslabón 1 — retraso no comunicado · **dominio:** ORGANIZATIVO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 5.37 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-16 · **alcance_cobertura:** GENERAL · **condicion:** —

C-054 — RSC-025

Descripción del control: Puntos de espera predefinidos, cubiertos y variables; nunca espera en vía abierta

Eslabón que rompe: Eslabón 2 — exposición en el punto · **dominio:** FISICO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 7.1, 7.2 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-16 · **alcance_cobertura:** GENERAL · **condicion:** —

C-055 — RSC-025

Descripción del control: Seguimiento de posición del vehículo y aviso automático de desviación sobre el horario previsto

Eslabón que rompe: Eslabón 1 — retraso no comunicado · **dominio:** DIGITAL · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 8.16 · **periodicidad_dias:** 90 · **fecha_ultima_verificacion:** — · **Plan:** PT-16 · **alcance_cobertura:** GENERAL · **condicion:** —

C-056 — RSC-015

Descripción del control: Retirada activa de datos personales y patrimoniales de agregadores y registros consultables

Eslabón que rompe: Eslabón 1 — agregación de fuentes · **dominio:** DIGITAL · **estado:** PLANIFICADO

evidencia: —

propietario_control: Repr. de la propiedad · **ref_27002:** 5.34, 5.7 · **periodicidad_dias:** 90 · **fecha_ultima_verificacion:** — · **Plan:** PT-02 · **alcance_cobertura:** GENERAL · **condicion:** —

C-057 — RSC-015

Descripción del control: Reducción de la señal física asociable al patrimonio: matrículas, rotulación y accesos identificables

Eslabón que rompe: Eslabón 2 — asociación con ubicaciones · **dominio:** FISICO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Jefe de seguridad · **ref_27002:** 7.1 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-02 · **alcance_cobertura:** GENERAL · **condicion:** —

C-058 — RSC-005

Descripción del control: Custodia física de las escrituras de poder y registro de su entrega y devolución

Eslabón que rompe: Eslabón 3 — disposición amparada en poderes; alcance condicionado al soporte material

dominio: FISICO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Resp. financiero · **ref_27002:** 7.10, 5.33 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-05 · **alcance_cobertura:** CONDICIONADO

condicion: C-058 protege el uso material de escrituras; no impide instrucciones falsas con poderes ya vigentes.

C-059 — RSC-006

Descripción del control: Verificación presencial obligatoria para órdenes ≥50.000 €: confirmación cara a cara con el solicitante antes de ejecutar; sin sustitución por canal remoto

Eslabón que rompe: Eslabón 3 — ejecución de la orden · **dominio:** FISICO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Resp. financiero · **ref_27002:** 8.5, 5.17 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-06 · **alcance_cobertura:** CONDICIONADO

condicion: C-059 solo para órdenes ≥50.000 €; no acredita cobertura física general de RSC-006.

C-065 — RSC-010

Descripción del control: Confirmación presencial con el principal para órdenes ≥50.000 €, conforme a DOC-007 R3 y §4

Eslabón que rompe: Eslabón 4 — ejecución sin verificación · **dominio:** FISICO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Resp. financiero · **ref_27002:** 8.5, 5.17 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-06 · **alcance_cobertura:** CONDICIONADO

condicion: C-065 solo para órdenes ≥50.000 €; no acredita cobertura física general de RSC-010.

C-061 — RSC-010

Descripción del control: Palabra de control acordada y custodiada en papel, verificable fuera de banda ante una orden por voz

Eslabón que rompe: Eslabón 3 — autorización de la orden · **dominio:** ORGANIZATIVO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Resp. financiero · **ref_27002:** 5.17 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-06 · **alcance_cobertura:** GENERAL · **condicion:** —

C-062 — RSC-010

Descripción del control: Bloqueo de órdenes por voz en banca: instrucción permanente firmada ante la entidad

Eslabón que rompe: Eslabón 3 — autorización de la orden · **dominio:** ORGANIZATIVO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Resp. financiero · **ref_27002:** 5.17, 8.5 · **periodicidad_dias:** 365 · **fecha_ultima_verificacion:** — · **Plan:** PT-06 · **alcance_cobertura:** GENERAL · **condicion:** —

C-063 — RSC-014

Descripción del control: Custodia física en caja fuerte de las credenciales y firmas del principal, con registro de retirada

Eslabón que rompe: Eslabón 1 — concentración de la identidad · **dominio:** FISICO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Dirección General · **ref_27002:** 7.10, 5.17 · **periodicidad_dias:** 180 · **fecha_ultima_verificacion:** — · **Plan:** PT-06 · **alcance_cobertura:** CONDICIONADO

condicion: C-063 protege la custodia física de credenciales y firmas; no cubre por sí solo compromiso del puesto o coacción.

C-064 — RSC-024

Descripción del control: Inventario físico de equipos y elementos de red de la residencia y la oficina, contrastado anualmente

Eslabón que rompe: Eslabón 1 — ausencia de criterio · **dominio:** ORGANIZATIVO · **estado:** PLANIFICADO

evidencia: —

propietario_control: Dirección General · **ref_27002:** 5.9, 7.8 · **periodicidad_dias:** 365 · **fecha_ultima_verificacion:** — · **Plan:** PT-15 · **alcance_cobertura:** GENERAL · **condicion:** —

Plan de tratamiento

PT-01 — RSC-001

Controles (ver hoja Controles): C-001 a C-005

Ref. Anexo A / DOC: A 5.10, 5.24, 5.25, 6.3, 6.8, 7.4, 8.1; DOC-008 §3, DOC-009 §5

Responsable: Jefe de seguridad · **Plazo:** 6 meses · **P res.:** 2 · **I res.:** 4 · **Nivel res.:** 8 · **Cat. res.:** Alto · **Estado:** EN CURSO

Aceptación del residual: Aceptado por Jefe de seguridad, propietario(s) del riesgo (ISO/IEC 27001 6.1.3 f); residual Alto ratificado por acto expreso del Comité de Seguridad Convergente (DOC-004 §4.4)

Registro de aceptación: Acta del Comité de 24/07/2026

Aprobación del plan por el propietario del riesgo: Aprobado por Jefe de seguridad — 24/07/2026 (acta del Comité de 24/07/2026)

PT-02 — RSC-002, RSC-015

Controles (ver hoja Controles): C-006 a C-008, C-056, C-057 · **Ref. Anexo A / DOC:** A 5.7, 5.10, 5.34, 7.1; DOC-008 §3 · **Responsable:** Repr. de la propiedad · **Plazo:** 6 meses · **P res.:** 2 · **I res.:** 3 · **Nivel res.:** 6 · **Cat. res.:** Alto · **Estado:** NO INICIADO

Aceptación del residual: Aceptado por Repr. de la propiedad, propietario(s) del riesgo (ISO/IEC 27001 6.1.3 f); residual Alto ratificado por acto expreso del Comité de Seguridad Convergente (DOC-004 §4.4)

Registro de aceptación: Acta del Comité de 24/07/2026

Aprobación del plan por el propietario del riesgo: Aprobado por Repr. de la propiedad — 24/07/2026 (acta del Comité de 24/07/2026)

PT-03 — RSC-003

Controles (ver hoja Controles): C-009, C-010 · **Ref. Anexo A / DOC:** A 8.1, 7.9, 6.3; DOC-008 §4 · **Responsable:** Jefe de seguridad · **Plazo:** 6 meses · **P res.:** 1 · **I res.:** 4 · **Nivel res.:** 4 · **Cat. res.:** Moderado · **Estado:** NO INICIADO

Aceptación del residual: Aceptado por Jefe de seguridad, propietario(s) del riesgo, con justificación documentada — residual Moderado (DOC-004 §4.4)

Registro de aceptación: Acta del Comité de 24/07/2026

Aprobación del plan por el propietario del riesgo: Aprobado por Jefe de seguridad — 24/07/2026 (acta del Comité de 24/07/2026)

PT-04 — RSC-004

Controles (ver hoja Controles): C-011, C-012 · **Ref. Anexo A / DOC:** A 6.6, 6.3, 5.14; DOC-006 §4 · **Responsable:** Dirección General · **Plazo:** 6 meses · **P res.:** 2 · **I res.:** 3 · **Nivel res.:** 6 · **Cat. res.:** Alto · **Estado:** EN CURSO

Aceptación del residual: Residual previsto conservado como hipótesis histórica. Revalidación y aceptación de la revisión pendientes; no acredita reducción efectiva.

Registro de aceptación: Acta del Comité de 24/07/2026

Aprobación del plan por el propietario del riesgo: Aprobación de la revisión pendiente por el propietario del riesgo. La aprobación histórica no se traslada automáticamente.

PT-05 — RSC-005

Controles (ver hoja Controles): C-013, C-014, C-058 · **Ref. Anexo A / DOC:** A 5.18, 5.16, 5.17, 7.10; DOC-006 §4 · **Responsable:** Resp. financiero · **Plazo:** 4 meses · **P res.:** 2 · **I res.:** 4 · **Nivel res.:** 8 · **Cat. res.:** Alto · **Estado:** EN CURSO

Aceptación del residual: Aceptado por Resp. financiero, propietario(s) del riesgo (ISO/IEC 27001 6.1.3 f); residual Alto ratificado por acto expreso del Comité de Seguridad Convergente (DOC-004 §4.4)

Registro de aceptación: Acta del Comité de 24/07/2026

Aprobación del plan por el propietario del riesgo: Aprobado por Resp. financiero — 24/07/2026 (acta del Comité de 24/07/2026)

PT-06 — RSC-006, RSC-007, RSC-010, RSC-014, RSC-016

Controles (ver hoja Controles): C-015 a C-020, C-059, C-061 a C-063, C-065 · **Ref. Anexo A / DOC:** A 5.14, 5.17, 8.5, 8.24, 7.10; DOC-007 · **Responsable:** Resp. financiero · **Plazo:** 2-4 meses · **P res.:** 1 · **I res.:** 4 · **Nivel res.:** 4 · **Cat. res.:** Moderado · **Estado:** EN CURSO

Aceptación del residual: Residual previsto conservado como hipótesis histórica. Revalidación y aceptación de la revisión pendientes; no acredita reducción efectiva.

Registro de aceptación: Acta del Comité de 24/07/2026

Aprobación del plan por el propietario del riesgo: Aprobación de la revisión pendiente por el propietario del riesgo. La aprobación histórica no se traslada automáticamente.

PT-07 — RSC-008, RSC-009

Controles (ver hoja Controles): C-021 a C-024

Ref. Anexo A / DOC: A 5.20, 5.22, 8.2, 8.20, 8.22, 7.4, 7.8; DOC-006 §5

Responsable: Jefe de seguridad · **Plazo:** 6 meses · **P res.:** 1 · **I res.:** 4 · **Nivel res.:** 4 · **Cat. res.:** Moderado · **Estado:** NO INICIADO

Aceptación del residual: Aceptado por Jefe de seguridad, propietario(s) del riesgo, con justificación documentada — residual Moderado (DOC-004 §4.4)

Registro de aceptación: Acta del Comité de 24/07/2026

Aprobación del plan por el propietario del riesgo: Aprobado por Jefe de seguridad — 24/07/2026 (acta del Comité de 24/07/2026)

PT-08 — RSC-011

Controles (ver hoja Controles): C-025, C-026 · **Ref. Anexo A / DOC:** A 7.2, 7.6, 8.22; DOC-006 · **Responsable:** Jefe de seguridad · **Plazo:** 6 meses · **P res.:** 2 · **I res.:** 3 · **Nivel res.:** 6 · **Cat. res.:** Alto · **Estado:** NO INICIADO

Aceptación del residual: Aceptado por Jefe de seguridad, propietario(s) del riesgo (ISO/IEC 27001 6.1.3 f); residual Alto ratificado por acto expreso del Comité de Seguridad Convergente (DOC-004 §4.4)

Registro de aceptación: Acta del Comité de 24/07/2026

Aprobación del plan por el propietario del riesgo: Aprobado por Jefe de seguridad — 24/07/2026 (acta del Comité de 24/07/2026)

PT-09 — RSC-012, RSC-022

Controles (ver hoja Controles): C-027 a C-031 · **Ref. Anexo A / DOC:** A 7.9, 8.1, 8.24, 6.7, 5.12; DOC-008 · **Responsable:** Jefe de seguridad · **Plazo:** 3 meses · **P res.:** 2 · **I res.:** 4 · **Nivel res.:** 8 · **Cat. res.:** Alto · **Estado:** NO INICIADO

Aceptación del residual: Aceptado por Jefe de seguridad, propietario(s) del riesgo (ISO/IEC 27001 6.1.3 f); residual Alto ratificado por acto expreso del Comité de Seguridad Convergente (DOC-004 §4.4)

Registro de aceptación: Acta del Comité de 24/07/2026

Aprobación del plan por el propietario del riesgo: Aprobado por Jefe de seguridad — 24/07/2026 (acta del Comité de 24/07/2026)

PT-10 — RSC-013

Controles (ver hoja Controles): C-032, C-033 · **Ref. Anexo A / DOC:** A 8.13, 7.10, 6.3 · **Responsable:** Dirección General · **Plazo:** 4 meses · **P res.:** 2 · **I res.:** 3 · **Nivel res.:** 6 · **Cat. res.:** Alto · **Estado:** NO INICIADO

Aceptación del residual: Aceptado por Dirección General, propietario(s) del riesgo (ISO/IEC 27001 6.1.3 f); residual Alto ratificado por acto expreso del Comité de Seguridad Convergente (DOC-004 §4.4)

Registro de aceptación: Acta del Comité de 24/07/2026

Aprobación del plan por el propietario del riesgo: Aprobado por Dirección General — 24/07/2026 (acta del Comité de 24/07/2026)

PT-11 — RSC-018

Controles (ver hoja Controles): C-034 a C-037 · **Ref. Anexo A / DOC:** A 5.36, 5.37, 7.1, 7.4, 8.15, 8.16 · **Responsable:** Jefe de seguridad · **Plazo:** 2 meses · **P res.:** 2 · **I res.:** 4 · **Nivel res.:** 8 · **Cat. res.:** Alto · **Estado:** NO INICIADO

Aceptación del residual: Aceptado por Jefe de seguridad, propietario(s) del riesgo (ISO/IEC 27001 6.1.3 f); residual Alto ratificado por acto expreso del Comité de Seguridad Convergente (DOC-004 §4.4)

Registro de aceptación: Acta del Comité de 24/07/2026

Aprobación del plan por el propietario del riesgo: Aprobado por Jefe de seguridad — 24/07/2026 (acta del Comité de 24/07/2026)

PT-12 — RSC-019

Controles (ver hoja Controles): C-038 a C-041 · **Ref. Anexo A / DOC:** A 5.3, 8.5, 5.12, 5.33, 7.10, 7.9; DOC-007 · **Responsable:** Resp. financiero · **Plazo:** 3 meses · **P res.:** 1 · **I res.:** 4 · **Nivel res.:** 4 · **Cat. res.:** Moderado · **Estado:** NO INICIADO

Aceptación del residual: Residual previsto conservado como hipótesis histórica. Revalidación y aceptación de la revisión pendientes; no acredita reducción efectiva.

Registro de aceptación: Acta del Comité de 24/07/2026

Aprobación del plan por el propietario del riesgo: Aprobación de la revisión pendiente por el propietario del riesgo. La aprobación histórica no se traslada automáticamente.

PT-13 — RSC-020, RSC-021

Controles (ver hoja Controles): C-042 a C-047 · **Ref. Anexo A / DOC:** A 5.19, 5.20, 7.2, 7.3, 7.6, 5.25; DOC-006 · **Responsable:** Jefe de seguridad · **Plazo:** 4 meses · **P res.:** 2 · **I res.:** 4 · **Nivel res.:** 8 · **Cat. res.:** Alto · **Estado:** NO INICIADO

Aceptación del residual: Residual previsto conservado como hipótesis histórica. Revalidación y aceptación de la revisión pendientes; no acredita reducción efectiva.

Registro de aceptación: Acta del Comité de 24/07/2026

Aprobación del plan por el propietario del riesgo: Aprobación de la revisión pendiente por el propietario del riesgo. La aprobación histórica no se traslada automáticamente.

PT-14 — RSC-023

Controles (ver hoja Controles): C-048 a C-050 · **Ref. Anexo A / DOC:** A 5.9, 5.12, 5.15, 5.33, 7.7, 7.10 · **Responsable:** Dirección General · **Plazo:** 6 meses · **P res.:** 2 · **I res.:** 3 · **Nivel res.:** 6 · **Cat. res.:** Alto · **Estado:** NO INICIADO

Aceptación del residual: Residual previsto conservado como hipótesis histórica. Revalidación y aceptación de la revisión pendientes; no acredita reducción efectiva.

Registro de aceptación: Acta del Comité de 24/07/2026

Aprobación del plan por el propietario del riesgo: Aprobación de la revisión pendiente por el propietario del riesgo. La aprobación histórica no se traslada automáticamente.

PT-15 — RSC-024

Controles (ver hoja Controles): C-051, C-052, C-064 · **Ref. Anexo A / DOC:** A 5.35, 5.22, 8.8, 8.9, 5.9 · **Responsable:** Dirección General · **Plazo:** 6 meses · **P res.:** 2 · **I res.:** 3 · **Nivel res.:** 6 · **Cat. res.:** Alto · **Estado:** NO INICIADO

Aceptación del residual: Residual previsto conservado como hipótesis histórica. Revalidación y aceptación de la revisión pendientes; no acredita reducción efectiva.

Registro de aceptación: Acta del Comité de 24/07/2026

Aprobación del plan por el propietario del riesgo: Aprobación de la revisión pendiente por el propietario del riesgo. La aprobación histórica no se traslada automáticamente.

PT-16 — RSC-025

Controles (ver hoja Controles): C-053 a C-055 · **Ref. Anexo A / DOC:** A 5.37, 7.1, 7.2, 8.16 · **Responsable:** Jefe de seguridad · **Plazo:** 2 meses · **P res.:** 2 · **I res.:** 4 · **Nivel res.:** 8 · **Cat. res.:** Alto · **Estado:** NO INICIADO

Aceptación del residual: Aceptado por Jefe de seguridad, propietario(s) del riesgo (ISO/IEC 27001 6.1.3 f); residual Alto ratificado por acto expreso del Comité de Seguridad Convergente (DOC-004 §4.4)

Registro de aceptación: Acta del Comité de 24/07/2026

Aprobación del plan por el propietario del riesgo: Aprobado por Jefe de seguridad — 24/07/2026 (acta del Comité de 24/07/2026)

Nota sobre el riesgo residual. Doce de los dieciséis planes cierran en residual Alto. No es un defecto de la valoración: es la consecuencia de la regla del máximo en un contexto cuyo activo final son personas, tres de ellas menores. Ningún control reduce por debajo de 4 el impacto sobre personas de un escenario de aproximación coactiva; lo que el tratamiento reduce es la probabilidad. Por eso el residual Alto no se acepta por defecto. La aceptación del riesgo residual corresponde al propietario del riesgo, conforme a ISO/IEC 27001 6.1.3 f), que es también quien aprueba el plan (columna «Aprobación del plan por el propietario del riesgo»); sobre ese acto, esta organización añade un requisito más estricto que la norma: todo residual Alto exige además ratificación expresa del Comité, registrada en acta, y es entrada obligatoria de la revisión por la dirección (SGSI-DOC-010 §3.1). Ningún plan admite residual Crítico. Regla de valoración en los planes que agrupan varios escenarios: el residual del plan se valora por el peor de los escenarios que agrupa, con la misma regla del máximo que se aplica al impacto. Es deliberadamente conservador y sobrestima el residual de los escenarios menores del grupo (RSC-007 y RSC-016 en PT-06, RSC-012 en PT-09 y RSC-020 en PT-13); la alternativa —un residual por escenario— multiplicaría las filas del plan sin cambiar ninguna decisión de aceptación.

Revisión 27/09/2026: PT-04 (HD-02), PT-06 (C-060/C-062/C-065 y alcance de C-016/C-019; RSC-014 pendiente), PT-12/PT-13 (HD-09), PT-14/PT-15 (dominios) requieren revalidación. Se conservan las puntuaciones previstas, no como resultado acreditado. Los demás planes conservan sus hipótesis; un dominio no aplicable no reduce por sí mismo el riesgo.

Las actas citadas son referencias narrativas del escenario ficticio; no se han redactado ni aportado como prueba de ejecución o de aprobación de esta revisión.